



Test Report

Unauthenticated GET-only Elasticsearch penetration test / security assessment

Report ID	GARGA-PT-20260828
Report version	1.0
Generated	2026-08-28 10:49:48 UTC
Assessor	Cuma Kurt
Classification	Confidential - Authorized Security Assessment
Assessment mode	Unauthenticated, GET-only, non-destructive
Risk posture	Critical score 55 / 100 Critical findings

1. Executive summary

This GET-only security scan recorded 3 finding(s) across 1 target(s). 1 finding(s) are marked EXPLOITABLE: unauthenticated read/write/admin access or a remote-compromise advisory class. The mark is listing emphasis, not confirmed exploitation. Critical findings indicate cluster takeover or equivalent impact if the HTTP port remains reachable. Contain network exposure and enable authentication before debating patch windows. Each finding below states why it appeared, what it costs if ignored, how to fix it, and what residual uncertainty remains. garga did not send credentials, writes, or exploit payloads.

Findings	3 (1 exploitable-class)
Assets with findings	1
CVE identifiers	0
Probes	1 submitted, 1 succeeded, 0 failed
Severity counts	critical 1, high 2, medium 0, low 0, info 0

2. Engagement overview

Identify unauthenticated exposure, transport weakness, missing authentication, public addressing, and potential Elasticsearch CVE matches on authorized HTTP targets.

This PDF is the engagement deliverable. Machine stdout (--format) is separate.

3. Scope

In scope

- Elasticsearch HTTP endpoints supplied to this garga scan run
- Network probes submitted during the run: 1 (1 succeeded, 0 failed)
- Unauthenticated GET / product fingerprinting
- GET-only capability discovery on likely or confirmed Elasticsearch identities
- Exposure checks: TLS scheme, anonymous access class, missing security APIs, public unicast IP
- Bundled or operator-supplied YAML CVE signature matching against advertised versions
- Finding-bearing assets recorded in this report: 1

Out of scope

- Authenticated testing, role-based authorization review, and API-key or token abuse
- Password spraying, credential stuffing, and brute force
- State-changing requests, exploit payloads, and proof-of-concept code execution
- OpenSearch and non-Elasticsearch HTTP services (OpenSearch is a negative fingerprint)
- DNS resolution used to classify hostnames as public
- Kibana, Logstash, Beats, and cloud control-plane APIs unless they were supplied as scan targets
- Source-code review, container image scanning, and host/OS configuration
- Physical security, social engineering, and denial-of-service load testing
- Certificate chain quality, TLS protocol/cipher review, and HTTP security headers beyond the TLS-present check

4. Rules of engagement

- Only GET requests are sent. Request bodies are not used.
- No credentials are attached on the scan path.
- Rate limits, timeouts, retries, and response-size bounds remain in force. --insecure skips certificate verification only.
- The scanner does not create, update, or delete indices, documents, users, or cluster settings.
- Findings do not fail the process by default; exit 0 means the scan finished.
- Report artifacts are generated locally with owner-only permissions and contain no executable content or external resources.

5. Methodology

Pre-engagement (PTES / NIST SP 800-115)

The operator supplies authorized targets, concurrency, and rate. garga does not discover the internet; it assesses only the in-scope input set.

Intelligence gathering (PTES Intelligence Gathering - OWASP WSTG Information Gathering)

Bounded GET / fingerprints Elasticsearch from multiple independent signals. Port 9200 is never treated as product evidence.

Threat modeling (PTES Threat Modeling)

The Elasticsearch HTTP surface is modeled as an unauthenticated network service. Adjacent products are out of scope unless targeted.

Vulnerability analysis (PTES Vulnerability Analysis - OWASP WSTG Configuration and Identity)

Exposure checks classify TLS, anonymous access, missing security APIs, and public addressing. CVE signatures match advertised versions.

Exploitation (PTES Exploitation - not performed)

Exploitation is deliberately omitted. No writes, shells, or advisory payloads are sent. Remotely usable classes are labeled EXPLOITABLE for triage only.

Post-exploitation (PTES Post-Exploitation - not performed)

No persistence, lateral movement, or data exfiltration was attempted. Impact statements are inferred from observed GET evidence and published advisories.

Reporting (PTES Reporting - CREST report structure)

This standalone report artifact is the engagement deliverable: executive, scope, methodology, risk model, technical findings with evidence, scenarios, remediation, and appendices.

Standards referenced

- PTES (Penetration Testing Execution Standard) - engagement phases
- NIST SP 800-115 - technical security testing and examination
- OWASP Web Security Testing Guide and OWASP Top 10:2021 - finding classification
- CREST / industry pentest report structure - document control, scope, methodology, findings, appendices
- CVSS - published advisory severity when a CVE is listed
- CWE - weakness class mapping for each finding

6. Risk rating methodology

Severity	Definition	Response
Critical	Immediate cluster takeover, anonymous administration, or equivalent loss of confidentiality, integrity, and availability if the HTTP port is reachable.	Treat as an incident. Contain network exposure and enforce authentication before debating patch windows.
High	Material confidentiality, integrity, or availability impact, including plaintext credentials in transit or a remote-compromise advisory class.	Remediate in the current hardening cycle. Do not defer behind unrelated feature work.
Medium	Attack-surface enlargement or a staging step toward a higher-impact issue. Includes many version-only CVE matches.	Plan and track to closure with a named owner.
Low	Defense-in-depth weakness with limited direct impact in isolation.	Fix opportunistically; combine with higher findings on the same asset.
Informational	Context for operators and the security program; no direct financial penalty is implied.	Retain evidence; no mandatory change.

7. Summary of findings

Domain		Count	Highest
Authentication and authorization		2	CRITICAL
Transport security		1	HIGH

#	ID	Severity	Title	Asset	CVSS	Status
1	F-001	CRITICAL	Elasticsearch likely allows unauthenticated cluster administration	http://127.0.0.1:19201/	-	Open / EXPLOITABLE

#	ID	Severity	Title	Asset	CVSS	Status
2	F-002	HIGH	Elasticsearch security APIs are not available	http://127.0.0.1:19201/	-	Open
3	F-003	HIGH	Elasticsearch is exposed without TLS	http://127.0.0.1:19201/	-	Open

8. Key findings for management

1. F-001 CRITICAL EXPLOITABLE

Elasticsearch likely allows unauthenticated cluster administration

Field	Value
Asset	http://127.0.0.1:19201/
Impact	Security APIs are unavailable and cluster APIs responded without credentials. Write and admin operations are inferred from that posture; they were not confirmed with a state-changing request.

2. F-002 HIGH

Elasticsearch security APIs are not available

Field	Value
Asset	http://127.0.0.1:19201/
Impact	The security authenticate API was unsupported. Native authentication, authorization, and API keys are likely disabled or not installed.

3. F-003 HIGH

Elasticsearch is exposed without TLS

Field	Value
Asset	http://127.0.0.1:19201/
Impact	The service was reached over HTTP. Credentials, queries, and document contents can be observed or modified in transit.

9. Technical findings

CRITICAL - 1 finding(s)

1. F-001 CRITICAL EXPLOITABLE

Elasticsearch likely allows unauthenticated cluster administration

Field	Value
Status	Open
Check	garga.exposure.anonymous_access
Asset	http://127.0.0.1:19201/ - Elasticsearch 8.19.20
Category	Authentication and authorization anonymous
Vector	Network - unauthenticated HTTP(S) to the Elasticsearch interface
Likelihood	Possible
Confidence	medium
OWASP	OWASP A07:2021 Identification and Authentication Failures
CWE	CWE-306 Missing Authentication for Critical Function

Field	Value
Description	Security APIs are unavailable and cluster APIs responded without credentials. Write and admin operations are inferred from that posture; they were not confirmed with a state-changing request.
Technical details	Unauthenticated HTTP GETs received cluster administration or superuser-equivalent evidence. Elasticsearch is treating anonymous clients as privileged operators.
Impact	Security APIs are unavailable and cluster APIs responded without credentials. Write and admin operations are inferred from that posture; they were not confirmed with a state-changing request.
Business impact	This is a full-compromise class. An internet or internal attacker can read and destroy indices, change cluster settings, create privileged users, and stage ransomware or silent exfiltration. Incident response, legal, and availability costs typically dwarf the work of turning security on.
Recommendation	Enable Elasticsearch security features and require authentication for HTTP APIs. Disable anonymous access unless a tightly scoped anonymous role is required.
Residual risk	Write or admin impact is inferred from missing security APIs plus unauthenticated cluster APIs. garga did not send a state-changing request, so confirm the live anonymous role before treating the class as proven.
Reproduction	1. Issue unauthenticated GET requests to the in-scope Elasticsearch HTTP endpoint, as performed by this assessment. 2. Record product identity, capability, transport scheme, and exposure evidence. 3. When signatures are enabled, compare the advertised version to the bundled CVE corpus. Exploitation, credential use, password spraying, and state-changing requests were not performed.
Evidence	class_admin_inferred - Admin access is inferred from missing security APIs plus unauthenticated cluster APIs.
Evidence	observed_target - The finding was produced for http://127.0.0.1:19201/.
Evidence	transport_http - The endpoint was reached over unencrypted HTTP.
Evidence	product_identity - Elasticsearch 8.19.20 was advertised by the endpoint.
Evidence	affected_resource - Affected resource class: anonymous.
References	https://www.elastic.co/guide/en/elasticsearch/reference/current/security-minimal-setup.html
Exploitable note	Unauthenticated access class. garga did not send a write.

HIGH - 2 finding(s)

2. F-002 HIGH

Elasticsearch security APIs are not available

Field	Value
Status	Open
Check	garga.exposure.security_unconfigured
Asset	http://127.0.0.1:19201/ - Elasticsearch 8.19.20
Category	Authentication and authorization security
Vector	Network - unauthenticated HTTP(S) to the Elasticsearch interface
Likelihood	Possible
Confidence	medium
OWASP	OWASP A05:2021 Security Misconfiguration
CWE	CWE-1188 Initialization of a Resource with an Insecure Default
Description	The security authenticate API was unsupported. Native authentication, authorization, and API keys are likely disabled or not installed.
Technical details	GET /_security/_authenticate was classified as unsupported. Native security features are disabled, not installed, or hidden behind a proxy that does not expose them.
Impact	The security authenticate API was unsupported. Native authentication, authorization, and API keys are likely disabled or not installed.

Field	Value
Business impact	Without a security realm, every reachable client is an operator. That usually leads to anonymous administration findings and removes the audit trail needed after an incident.
Recommendation	Enable Elasticsearch security features and verify that GET /_security/_authenticate is served. Do not run a cluster without authentication in an untrusted network.
Residual risk	Unsupported security APIs can also mean a version or proxy limitation. Confirm xpack.security (or equivalent) is enabled on every HTTP node, not only that a load balancer returned 404.
Reproduction	1. Issue unauthenticated GET requests to the in-scope Elasticsearch HTTP endpoint, as performed by this assessment. 2. Record product identity, capability, transport scheme, and exposure evidence. 3. When signatures are enabled, compare the advertised version to the bundled CVE corpus. Exploitation, credential use, password spraying, and state-changing requests were not performed.
Evidence	security_api_unsupported - The security API was classified as unsupported.
Evidence	observed_target - The finding was produced for http://127.0.0.1:19201/.
Evidence	transport_http - The endpoint was reached over unencrypted HTTP.
Evidence	product_identity - Elasticsearch 8.19.20 was advertised by the endpoint.
Evidence	affected_resource - Affected resource class: security.
References	https://www.elastic.co/guide/en/elasticsearch/reference/current/security-minimal-setup.html

3. F-003 HIGH Elasticsearch is exposed without TLS

Field	Value
Status	Open
Check	garga.tls.not_enabled
Asset	http://127.0.0.1:19201/ - Elasticsearch 8.19.20
Category	Transport security transport
Vector	Network - unauthenticated HTTP(S) to the Elasticsearch interface
Likelihood	Likely
Confidence	high
OWASP	OWASP A02:2021 Cryptographic Failures
CWE	CWE-319 Cleartext Transmission of Sensitive Information
Description	The service was reached over HTTP. Credentials, queries, and document contents can be observed or modified in transit.
Technical details	The Elasticsearch HTTP interface was reached with the HTTP scheme. TLS was not used for this connection, so the assessment observed plaintext transport.
Impact	The service was reached over HTTP. Credentials, queries, and document contents can be observed or modified in transit.
Business impact	A man-in-the-middle position can steal operator credentials, API keys, or Bearer tokens, read indexed data, and inject queries. Encryption-in-transit controls required by most security programs will fail this endpoint.
Recommendation	Enable TLS on the Elasticsearch HTTP interface and disable plaintext HTTP. Require HTTPS at any reverse proxy in front of the cluster.
Residual risk	garga did not inspect certificate quality, protocol versions, or cipher suites. Enabling TLS is necessary but not sufficient; weak TLS still needs a follow-up review.
Reproduction	1. Issue unauthenticated GET requests to the in-scope Elasticsearch HTTP endpoint, as performed by this assessment. 2. Record product identity, capability, transport scheme, and exposure evidence. 3. When signatures are enabled, compare the advertised version to the bundled CVE corpus. Exploitation, credential use, password spraying, and state-changing requests were not performed.
Evidence	scheme_http - The Elasticsearch endpoint used the HTTP scheme.

Field	Value
Evidence	observed_target - The finding was produced for http://127.0.0.1:19201/.
Evidence	product_identity - Elasticsearch 8.19.20 was advertised by the endpoint.
Evidence	affected_resource - Affected resource class: transport.
References	https://www.elastic.co/guide/en/elasticsearch/reference/current/configuring-tls.html

10. Attack scenarios

CRITICAL Unauthenticated access over plaintext transport

Anonymous HTTP access on an unencrypted channel allows both unauthorized API use and interception of any later credentials or queries on the same path. Target: http://127.0.0.1:19201/.

Supporting findings: F-001, F-002, F-003

11. Remediation roadmap

P0 Immediate

- http://127.0.0.1:19201/ - Enable Elasticsearch security features and require authentication for HTTP APIs. Disable anonymous access unless a tightly scoped anonymous role is required.

P1 Urgent

- http://127.0.0.1:19201/ - Enable Elasticsearch security features and verify that GET /_security/_authenticate is served. Do not run a cluster without authentication in an untrusted network.
- http://127.0.0.1:19201/ - Enable TLS on the Elasticsearch HTTP interface and disable plaintext HTTP. Require HTTPS at any reverse proxy in front of the cluster.

P2 Planned

None.

P3 Optimization

None.

12. Positive observations

- No public-unicast-IP finding was emitted. Hostnames were not resolved, so DNS or load-balancer public addressing may still exist.
- No version-signature CVE match was emitted. That does not prove the build is patched; signatures can miss unpublished issues and local backports.

13. Coverage, limitations, and residual testing gaps

Duration 517ms

Scanner garga/v0.1.0

- Only successfully probed Elasticsearch identities can produce exposure or signature findings. Failed probes are coverage gaps, not clean results.
- Probe telemetry: 1 submitted, 1 succeeded, 0 failed.
- Authenticated authorization, internal node-to-node traffic, and non-HTTP interfaces were not tested.
- Hostname targets are not classified as public by IP checks because DNS is not resolved.
- CVE hits remain potential until patch status and attack preconditions are confirmed on the live build.
- Time-boxed automated testing cannot enumerate every Elasticsearch plugin, proxy transform, or later-introduced issue.

Appendix A - Asset inventory

Target	Product	Version	Findings	Highest	Expl.
http://127.0.0.1:19201/	Elasticsearch	8.19.20	3	CRITICAL	1

Appendix B - CVE catalog

No CVE identifiers were matched.

Appendix C - Glossary

Term	Meaning
Finding	One evidence-backed observation with a stable check ID, severity, and affected asset.
EXPLOITABLE	Listing emphasis for unauthenticated read/write/admin access or a remote-compromise advisory class. Not confirmed exploitation.
CVSS	Published Common Vulnerability Scoring System value from the advisory, when present. It is not a live exploitability score for this engagement.
GET-only	The scanner sends HTTP GET without a request body and does not change cluster state.
Potential CVE	The advertised version is in an affected range. The vulnerable code path was not proven reachable.
Confidence	How directly the observation is supported by API evidence versus inference.
Residual risk	What remains uncertain after the recommended control is applied, or what this methodology could not prove.

Disclaimer

- This document is a confidential authorized security-assessment report. It is intended only for the system owner and named recipients. Redistribution without authorization may be unlawful.
- Testing was performed only against targets supplied to garga scan. Use against systems without authorization is outside the tool's purpose and may be illegal.
- The engagement was unauthenticated and GET-only. garga did not send credentials, password sprays, write requests, or exploit payloads. Absence of a finding is not a warranty that the cluster is safe on authenticated, internal, or adjacent paths.
- Signature (CVE) matches are potential: they are version and capability evidence, not confirmed exploitation. The EXPLOITABLE mark is listing emphasis for remotely usable compromise classes, not proof that an exploit succeeded.
- Recommendations are advisory. garga did not apply configuration changes. Validate fixes in a controlled change process before production rollout.

Assessor Cuma Kurt | <https://www.linkedin.com/in/cuma-kurt-34414917/> | <https://github.com/cumakurt>